# CCS113 MIDTERM LABORATORY EXAM

## PENTRATION TESTING



# THREATS
## MEMBERS



Magbayao,
Jonathan



Melu,
John Lloyd



Palentinos,
Althea Kaye



Samson,
Marco



Reves,
Mark Jerome



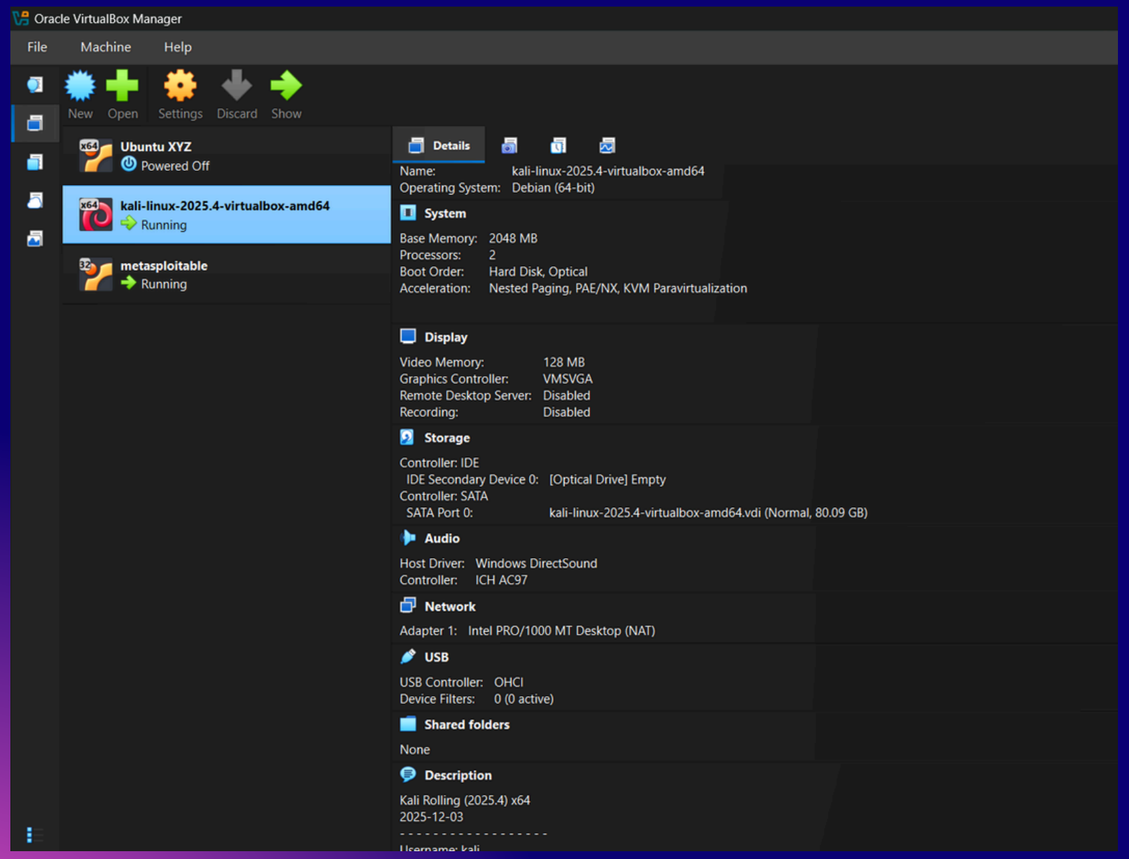
# OBJECTIVE:

The objective of this lab activity is to introduce participants to the basics of penetration testing. Participants will learn how to assess the security of a target system, identify vulnerabilities, and exploit them for ethical testing purposes. This lab is for educational purposes and should only be performed on systems you have permission to test.



# PART 1 SETTING UP THE VIRTUAL ENVIRONMENTS

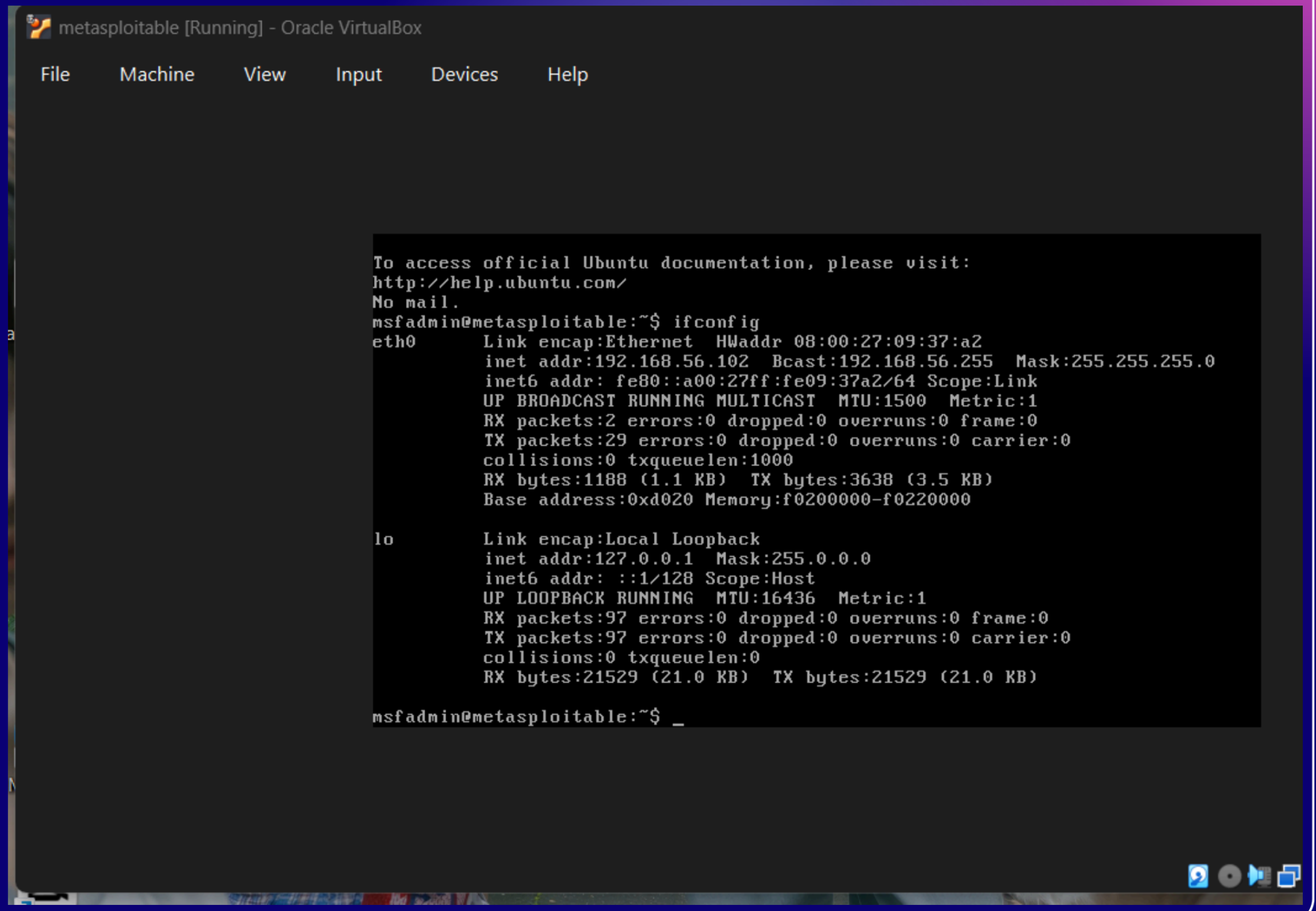





- we set up the virtual environment needed for penetration testing. We installed VirtualBox and imported Kali Linux as our attacker machine and Metasploitable as our target/victim machine. Both virtual machines were configured to use a Host-Only Adapter network so they can communicate with each other privately. After booting both VMs, we used the ifconfig command on Metasploitable to identify its IP address, which will be used in the scanning and exploitation phases.

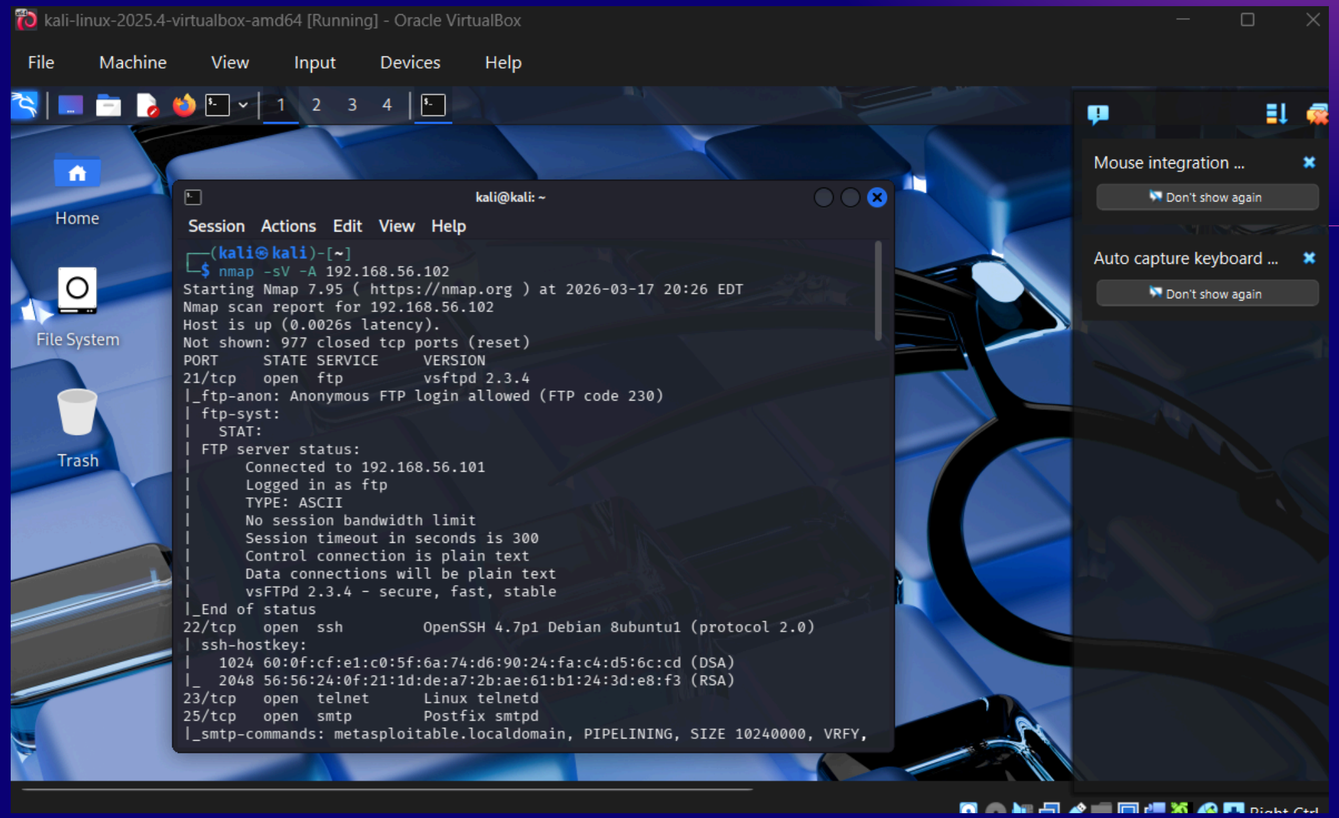
- We used VirtualBox to run two virtual machines — Kali Linux (attacker) and Metasploitable (target)

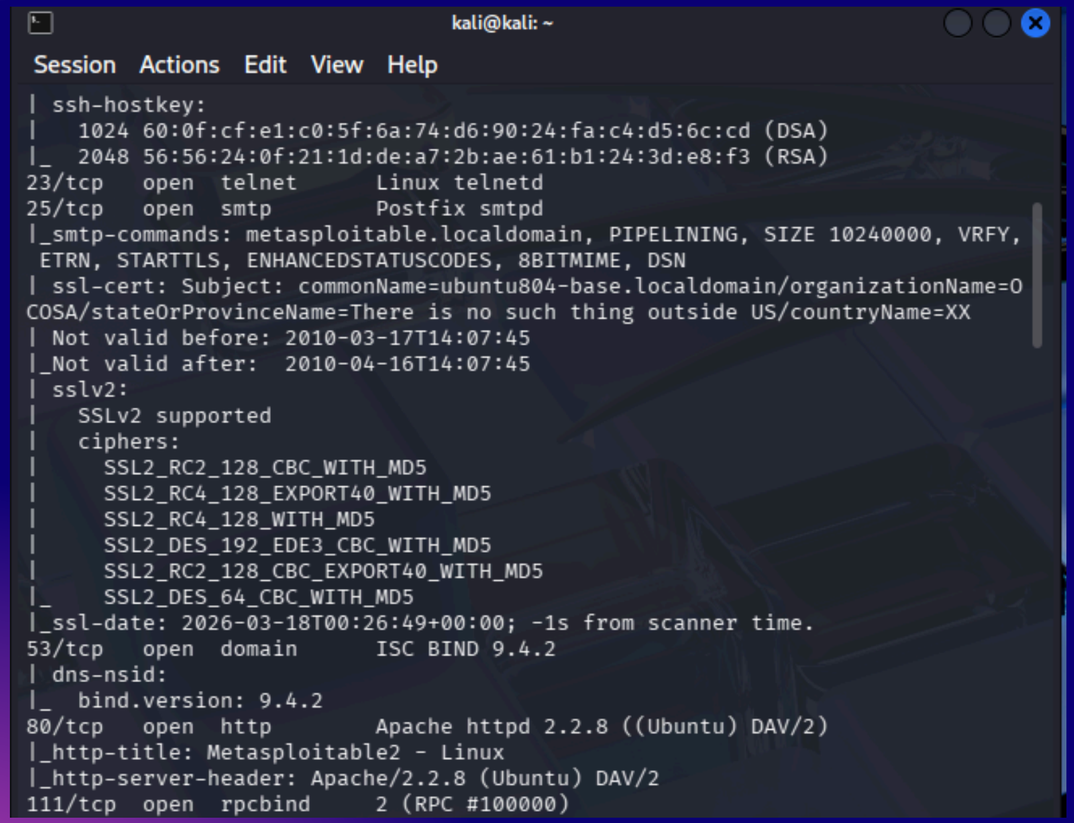
- we used the ifconfig command on Metasploitable to identify its IP address, which will be used in the scanning and exploitation phases."

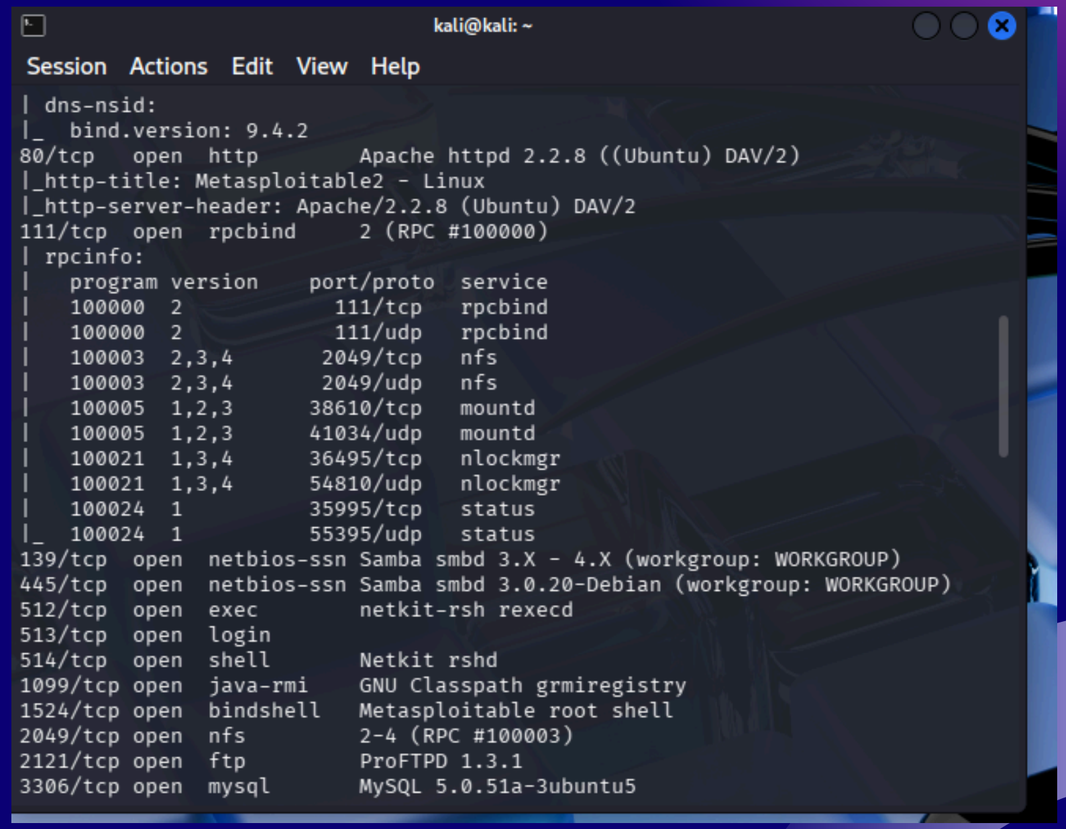


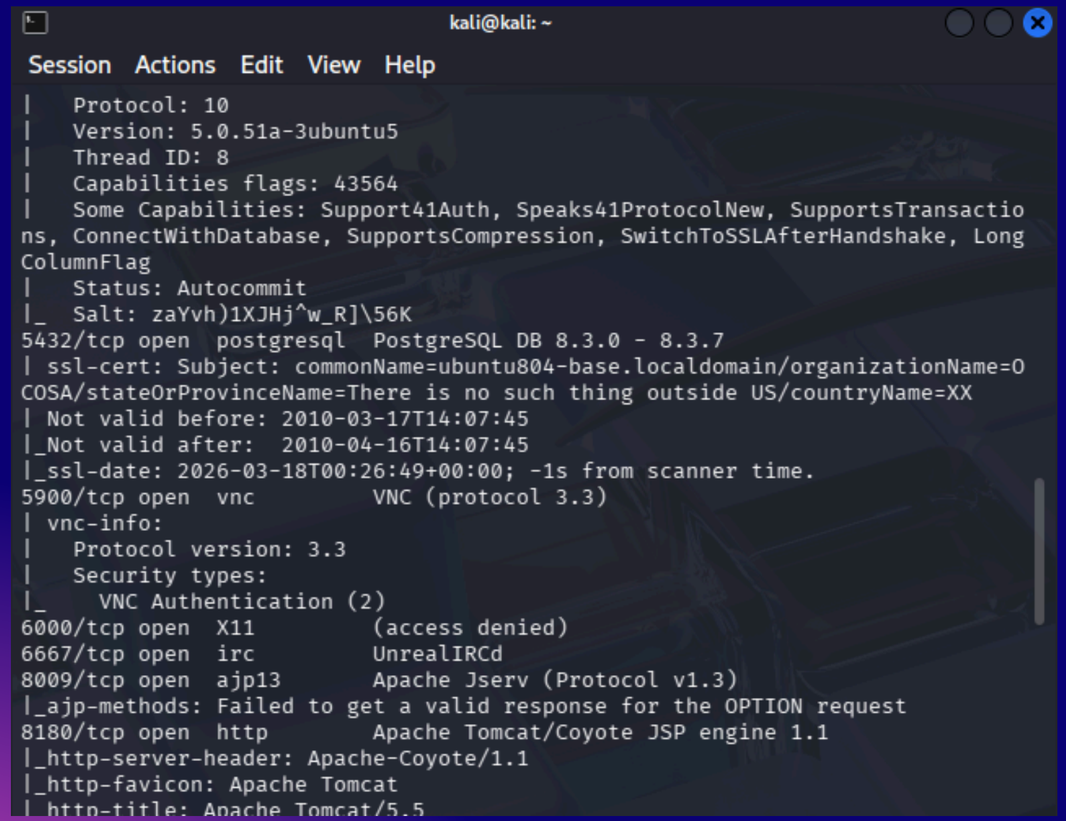
# PART 2 SCANNING AND ENUMERATION

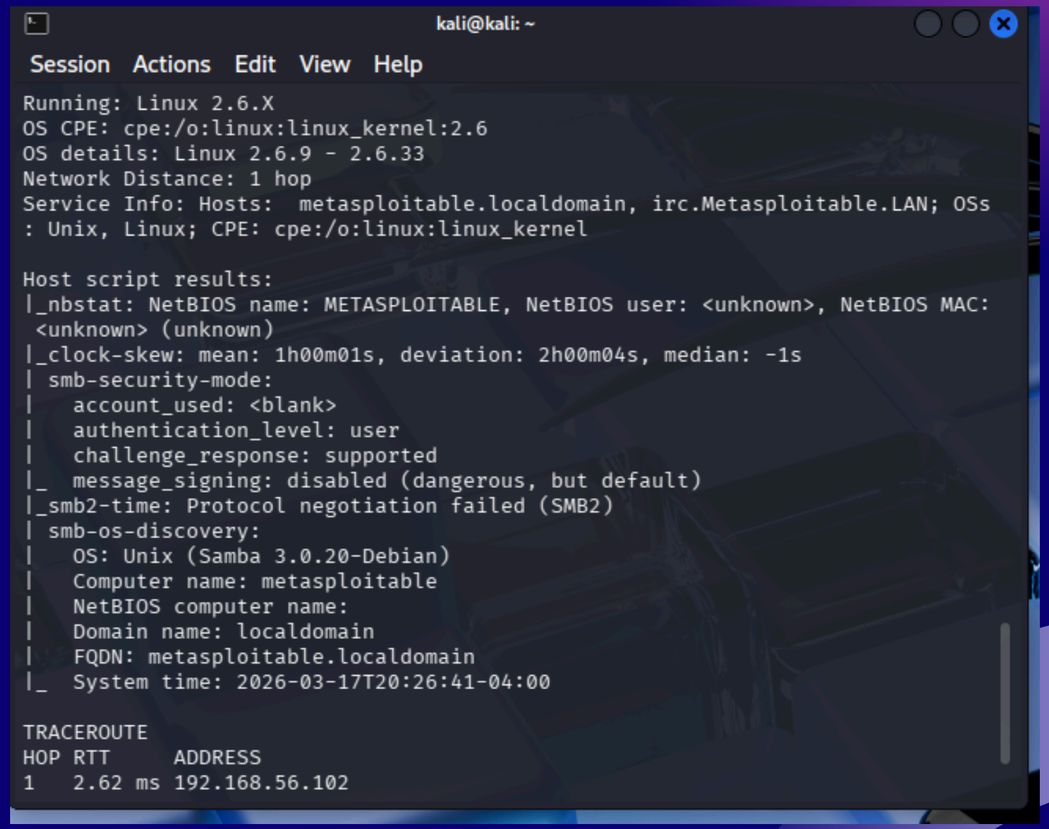
In this part, we performed network scanning and enumeration on the target machine using nmap. We opened a terminal in Kali Linux and ran the command nmap -sV against Metasploitable's IP address. The scan revealed several open ports and running services. These open ports and services will be analyzed further in the vulnerability assessment phase

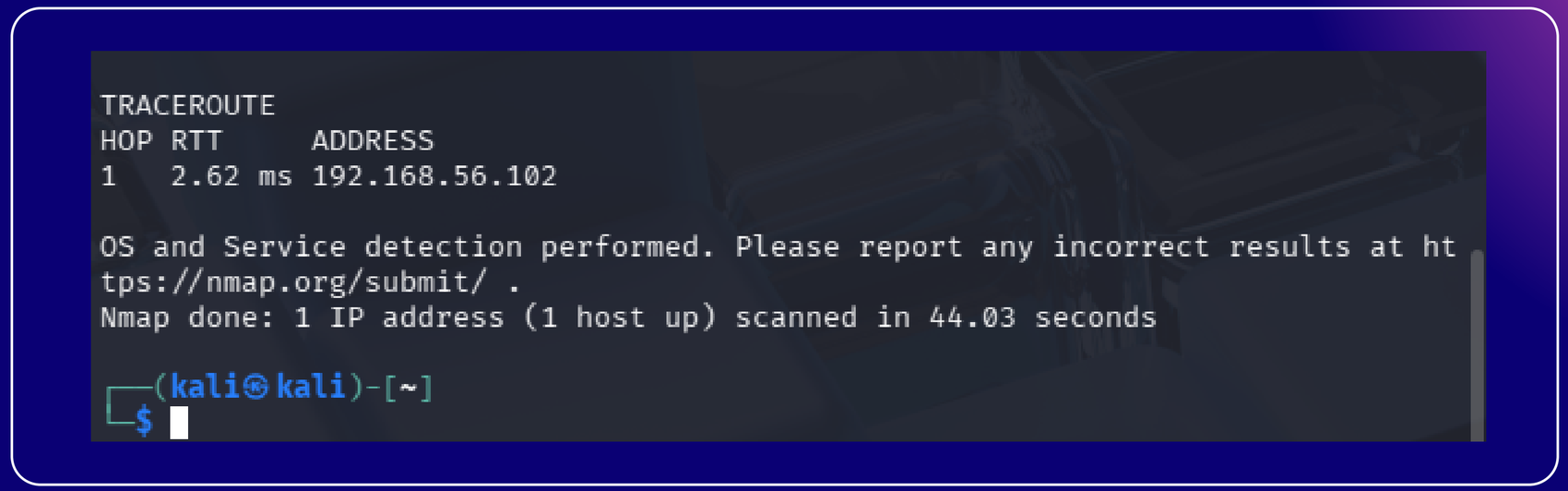



kali@kali: ~
Session Actions Edit View Help
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
| sslv2:
| SSLv2 supported
| ciphers:
| SSL2_RC2_128_CBC_WITH_MD5
| SSL2_RC4_128_EXPORT40_WITH_MD5
| SSL2_RC4_128_WITH_MD5
| SSL2_DES_192_EDE3_CBC_WITH_MD5
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ssl-date: 2026-03-18T00:26:49+00:00; -1s from scanner time.
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open rpcbind 2 (RPC #100000)


kali@kali: ~
Session Actions Edit View Help
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2 111/tcp rpcbind
| 100000 2 111/udp rpcbind
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 38610/tcp mountd
| 100005 1,2,3 41034/udp mountd
| 100021 1,3,4 36495/tcp nlockmgr
| 100021 1,3,4 54810/udp nlockmgr
| 100024 1 35995/tcp status
|_ 100024 1 55395/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5


kali@kali: ~
Session Actions Edit View Help
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 8
| Capabilities flags: 43564
| Some Capabilities: Support41Auth, Speaks41ProtocolNew, SupportsTransactions, ConnectWithDatabase, SupportsCompression, SwitchToSSLAfterHandshake, LongColumnFlag
| Status: Autocommit
|_ Salt: zaYvh)1XJHj^w_R]\56K
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-03-18T00:26:49+00:00; -1s from scanner time.
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
| http-title: Apache Tomcat/5.5

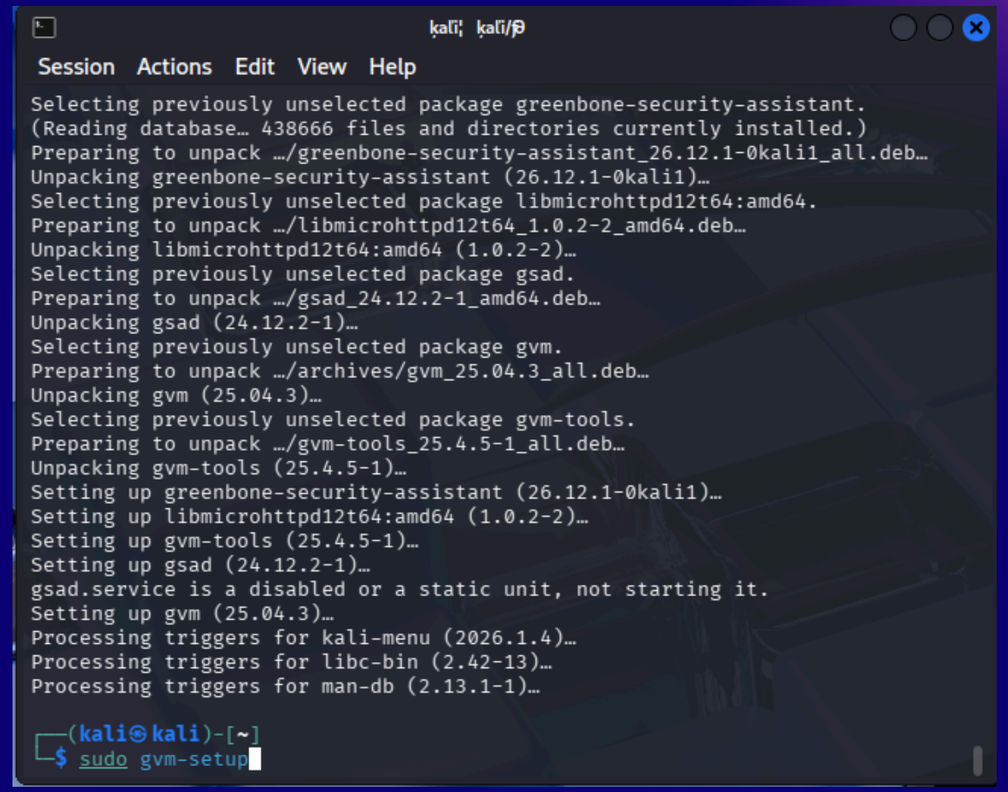

kali@kali: ~
Session Actions Edit View Help
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
Host script results:
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h00m01s, deviation: 2h00m04s, median: -1s
| smb-security-mode:
| account_used: <blank>
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2026-03-17T20:26:41-04:00
TRACEROUTE
HOP RTT ADDRESS
1 2.62 ms 192.168.56.102



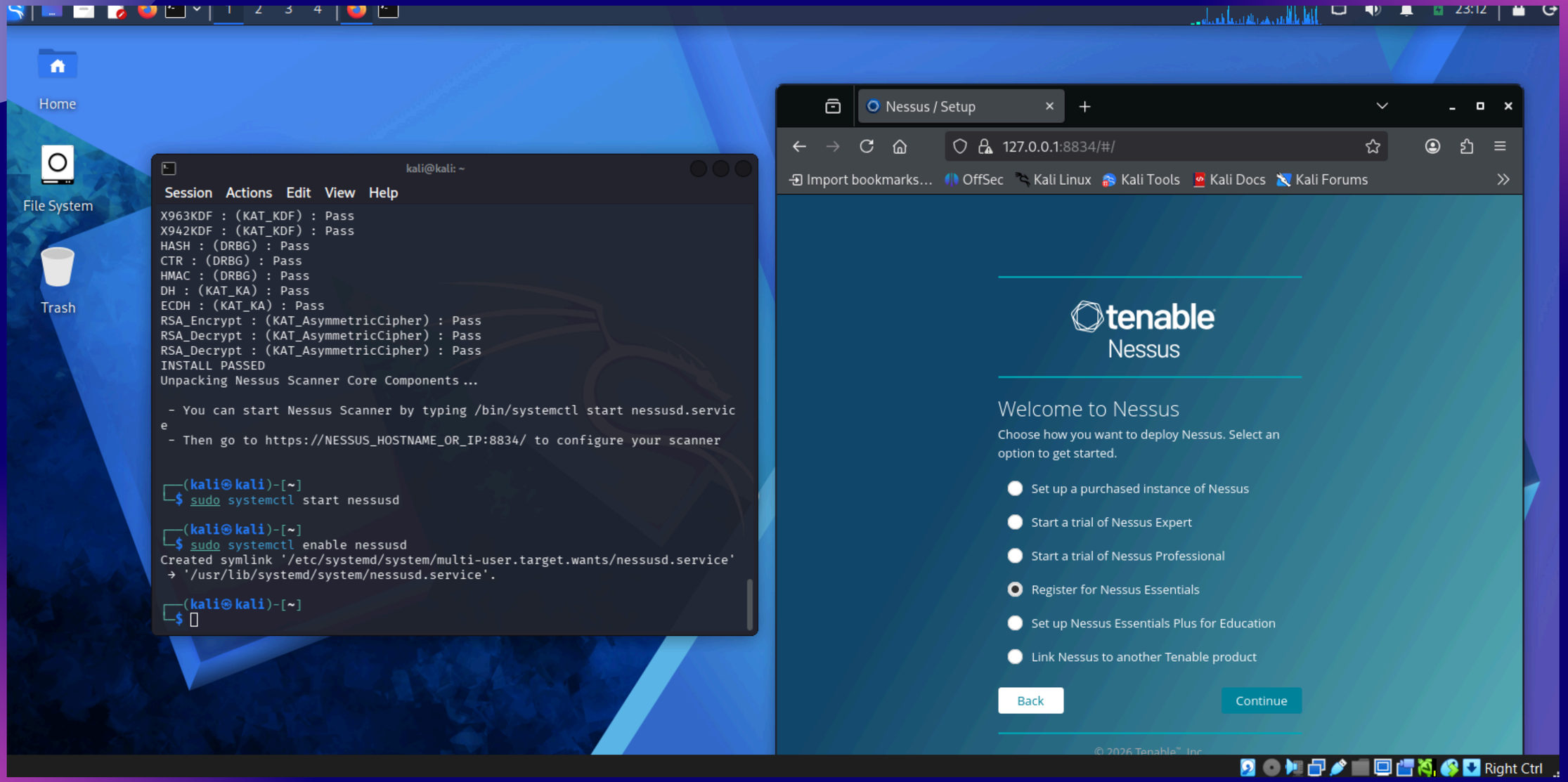

The scan revealed multiple open ports including FTP (21), SSH (22), HTTP (80), and MySQL (3306)

# PART 3 VULNERABILITY ASSESSMENT

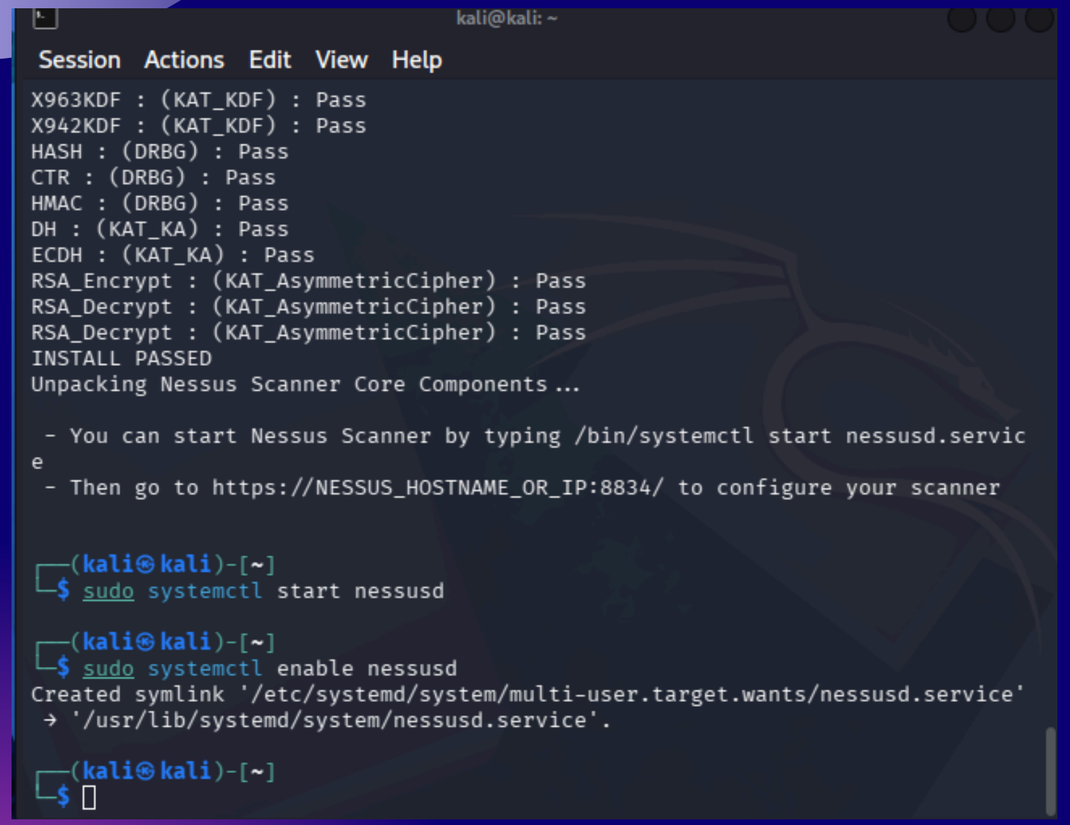
we performed a vulnerability assessment on the target machine using Nessus Essentials.. We started the GVM service on Kali Linux and accessed the Nessus web interface through the browser. We created a new scan task targeting Metasploitable's IP address and launched the scan. The results revealed several critical and high-severity vulnerabilities.

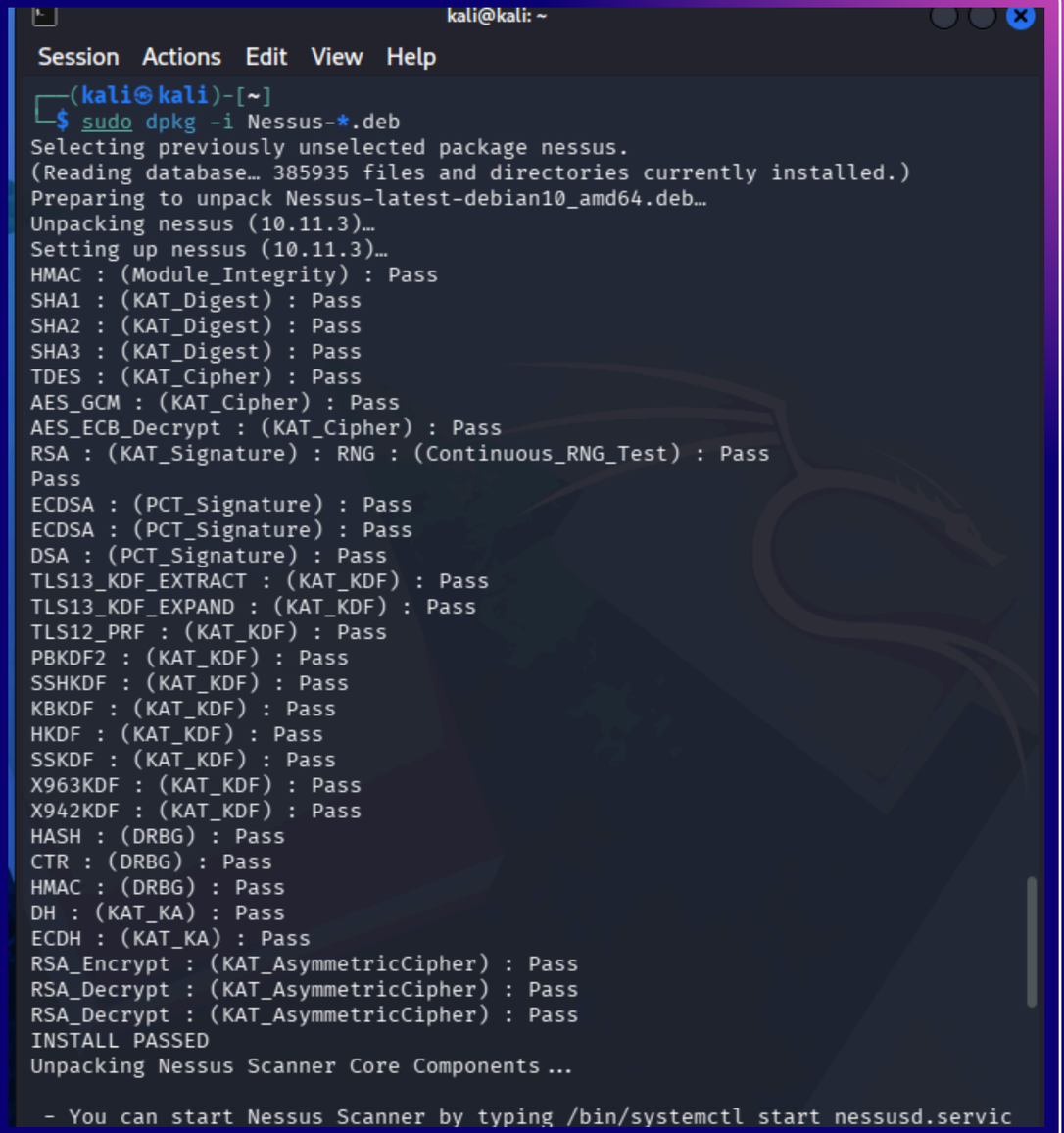


# Setup Nessus

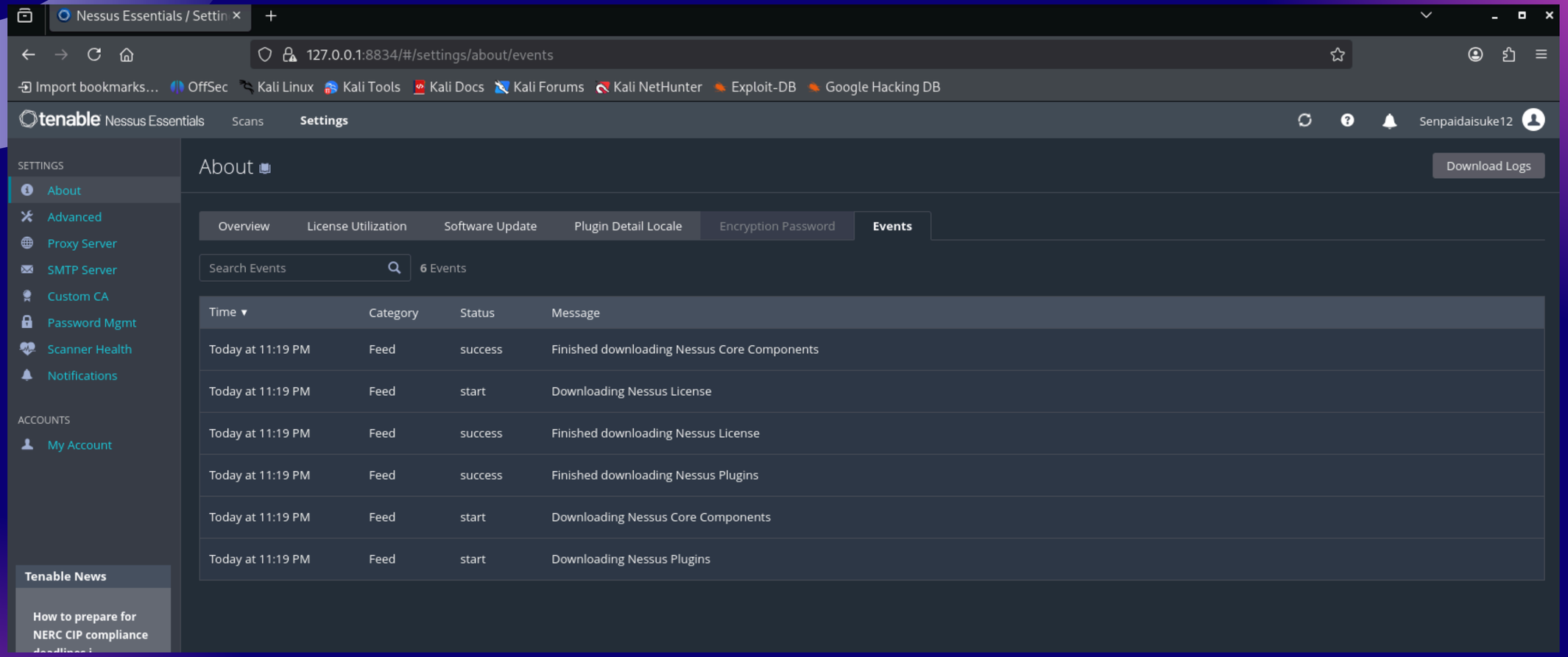


# Setup Nessus

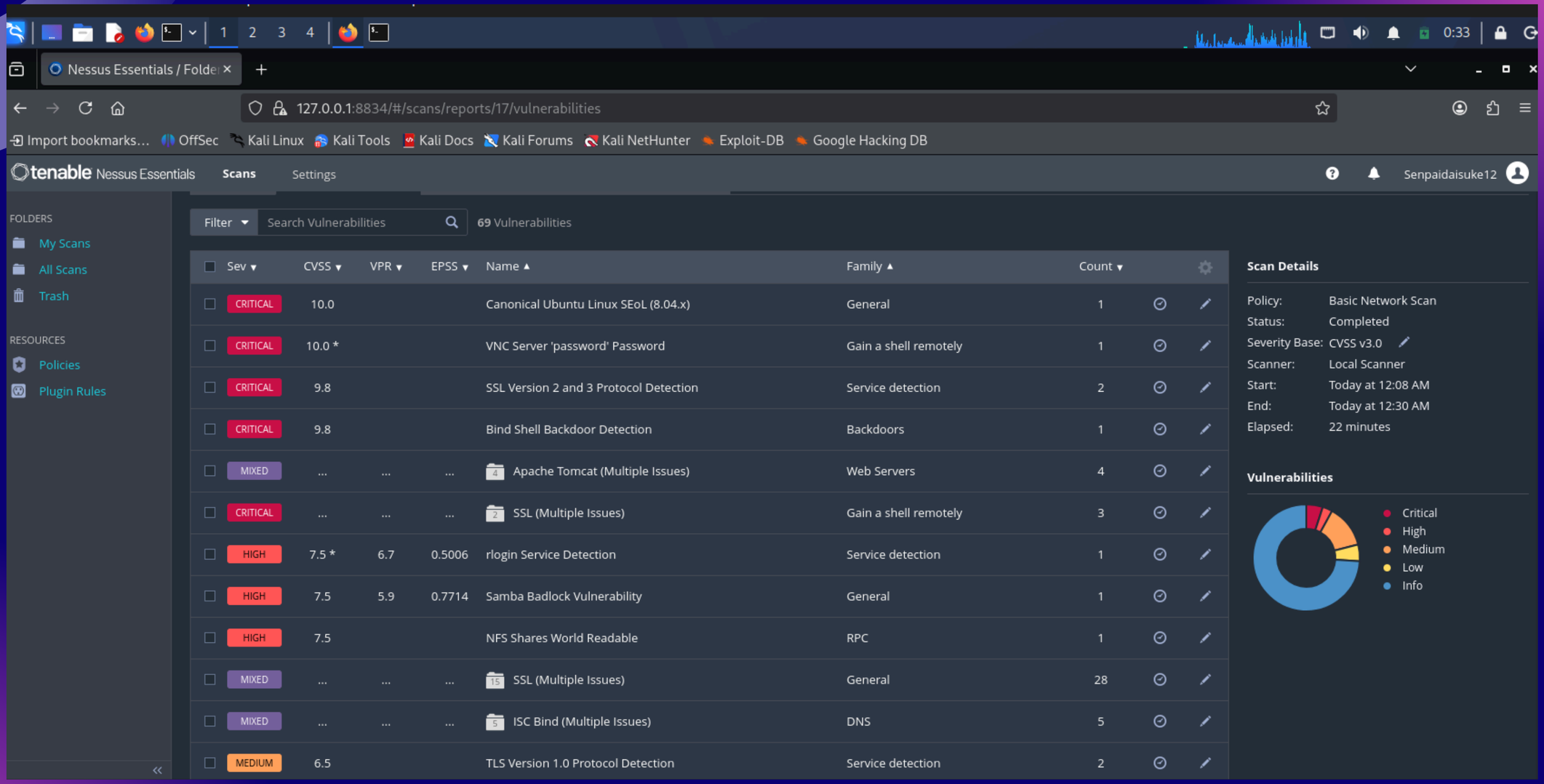


# Setup Nessus

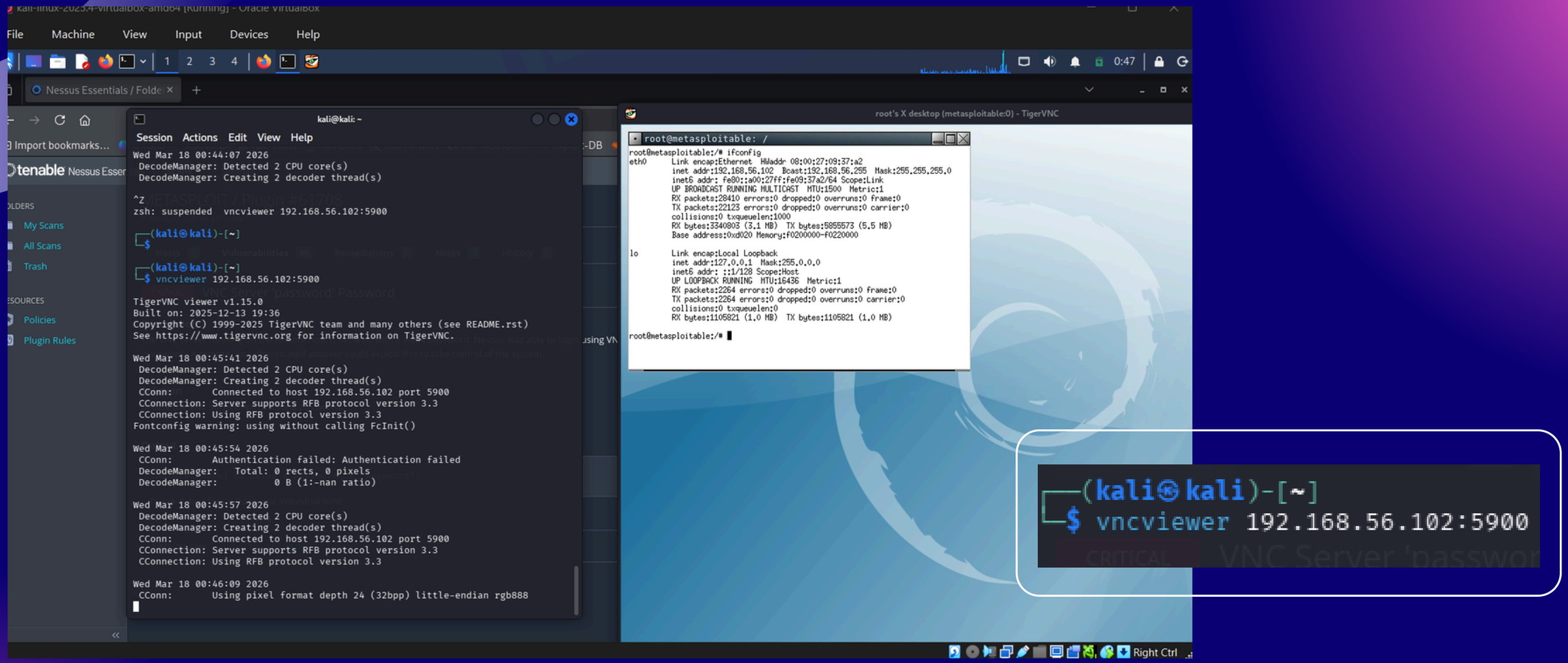



we installed and configured Nessus Essentials inside the Kali Linux virtual machine. We accessed the Nessus web interface through the browser at 127.0.0.1:8834. As shown in the Events log under Settings, Nessus successfully completed all necessary downloads including the Nessus Plugins, Nessus License, and Nessus Core Components. This confirms that Nessus is fully set up and ready to perform vulnerability scanning on the target machine.


Nessus Essentials / Folde
127.0.0.1:8834/#/scans/reports/17/vulnerabilities
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
tenable Nessus Essentials
Scans
Settings
Senpaidaisuke12
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Filter
Search Vulnerabilities
69 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
CRITICAL 10.0 Canonical Ubuntu Linux SEoL (8.04.x) General 1
CRITICAL 10.0 * VNC Server 'password' Password Gain a shell remotely 1
CRITICAL 9.8 SSL Version 2 and 3 Protocol Detection Service detection 2
CRITICAL 9.8 Bind Shell Backdoor Detection Backdoors 1
MIXED ... ... ... Apache Tomcat (Multiple Issues) Web Servers 4
CRITICAL ... ... ... SSL (Multiple Issues) Gain a shell remotely 3
HIGH 7.5 * 6.7 0.5006 rlogin Service Detection Service detection 1
HIGH 7.5 5.9 0.7714 Samba Badlock Vulnerability General 1
HIGH 7.5 NFS Shares World Readable RPC 1
MIXED ... ... ... SSL (Multiple Issues) General 28
MIXED ... ... ... ISC Bind (Multiple Issues) DNS 5
MEDIUM 6.5 TLS Version 1.0 Protocol Detection Service detection 2
Scan Details
Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 12:08 AM
End: Today at 12:30 AM
Elapsed: 22 minutes
Vulnerabilities
Critical
High
Medium
Low
Info

The scan shows that the target system is highly vulnerable and easy to hack. Here are the main issues:

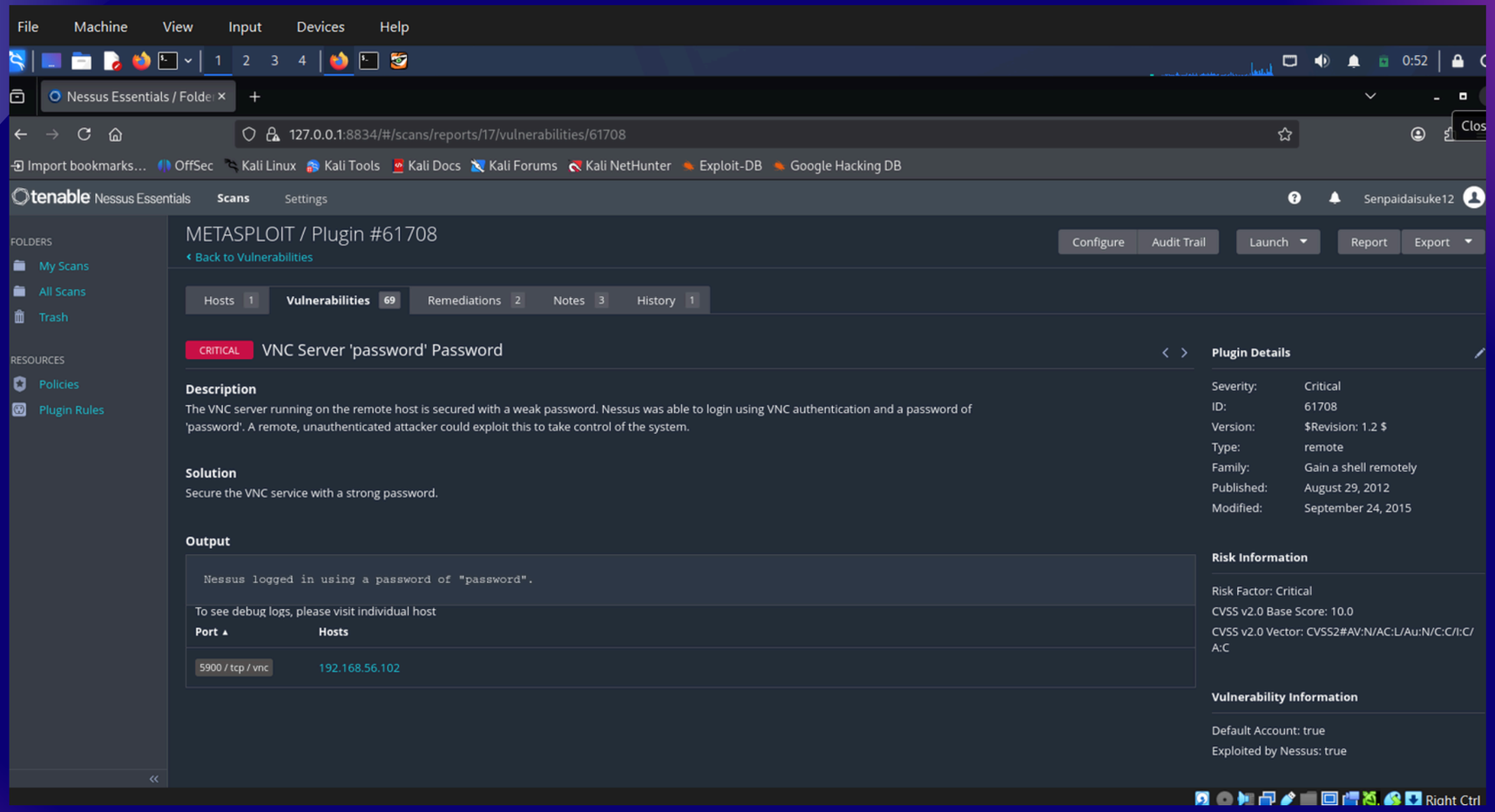
- Weak Passwords: The VNC remote desktop uses the password password, allowing anyone to log in instantly.
- Open Backdoor: A "Bind Shell" is active, giving an attacker a direct "secret entrance" to run commands.
- Ancient Software: It uses Ubuntu 8.04, which is nearly 20 years old. It has many unpatched security holes because it no longer gets updates.
- Broken Encryption: It uses old SSL/TLS versions that allow hackers to "eavesdrop" and steal data sent over the network.
- Unsecured Files: Network file shares (NFS) are "World Readable," meaning anyone can open and steal files without a password.
- Summary: An attacker can easily take full control of this machine using basic tools in Metasploit.



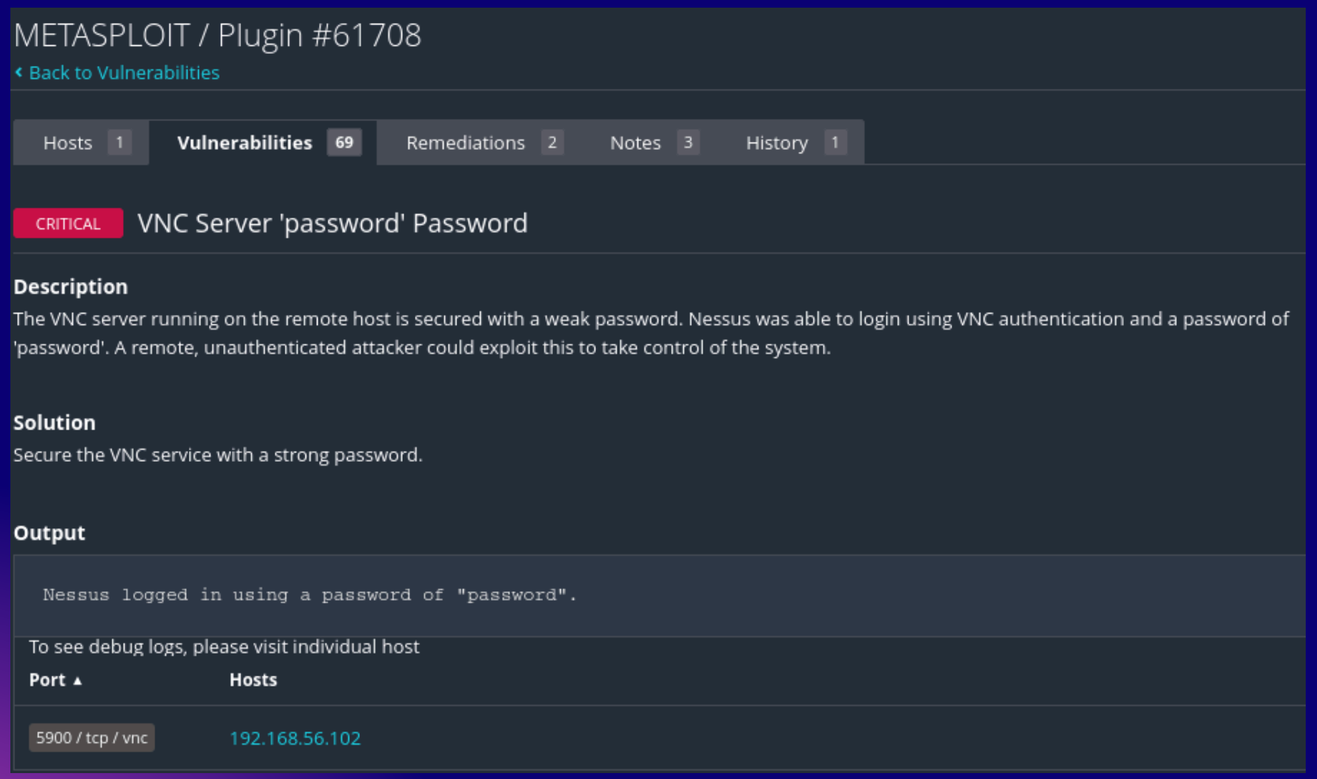

We used TigerVNC viewer from Kali Linux to remotely connect to the Metasploitable target machine at IP address 192.168.56.102 on port 5900. The right side shows the Metasploitable desktop with the ifconfig command output, confirming the target machine's IP address is 192.168.56.102. This demonstrates successful remote access to the target system through the VNC service.

# PART 4 EXPLOITATION

we performed a vulnerability assessment on the target machine using Nessus Essentials.. We started the GVM service on Kali Linux and accessed the Nessus web interface through the browser. We created a new scan task targeting Metasploitable's IP address and launched the scan. The results revealed several critical and high-severity vulnerabilities.



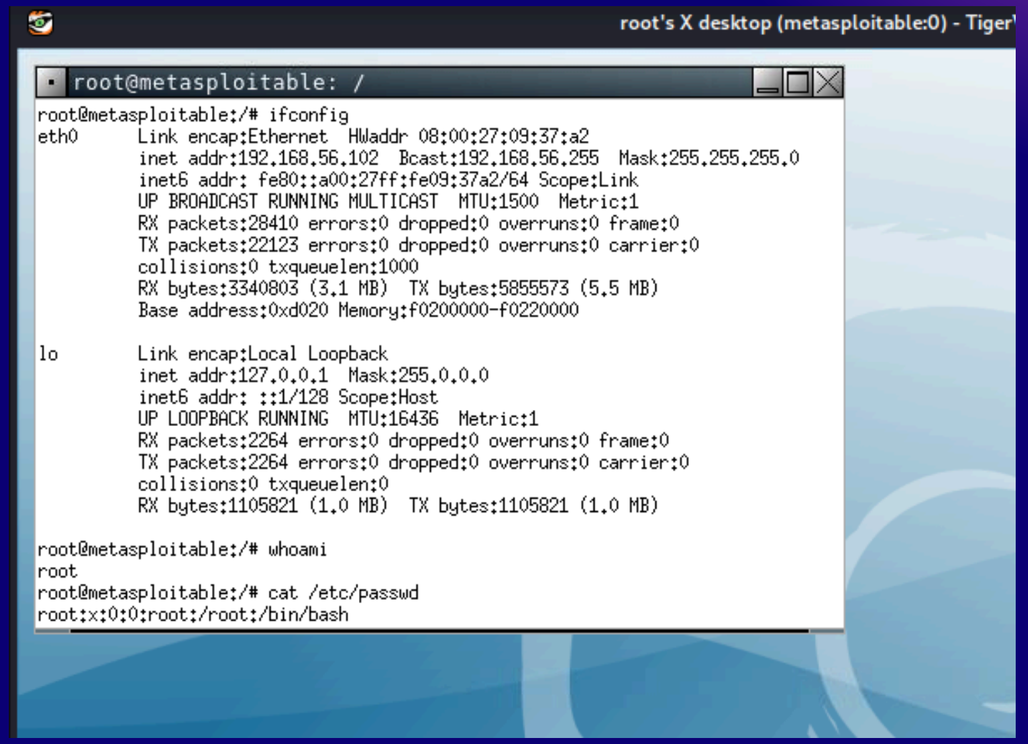

Nessus identified a CRITICAL vulnerability on the target machine — the VNC Server is secured with a weak default password of 'password'. This means any attacker can remotely log in and take full control of the system without authorization. Nessus confirmed this by successfully logging in using VNC authentication on port 5900

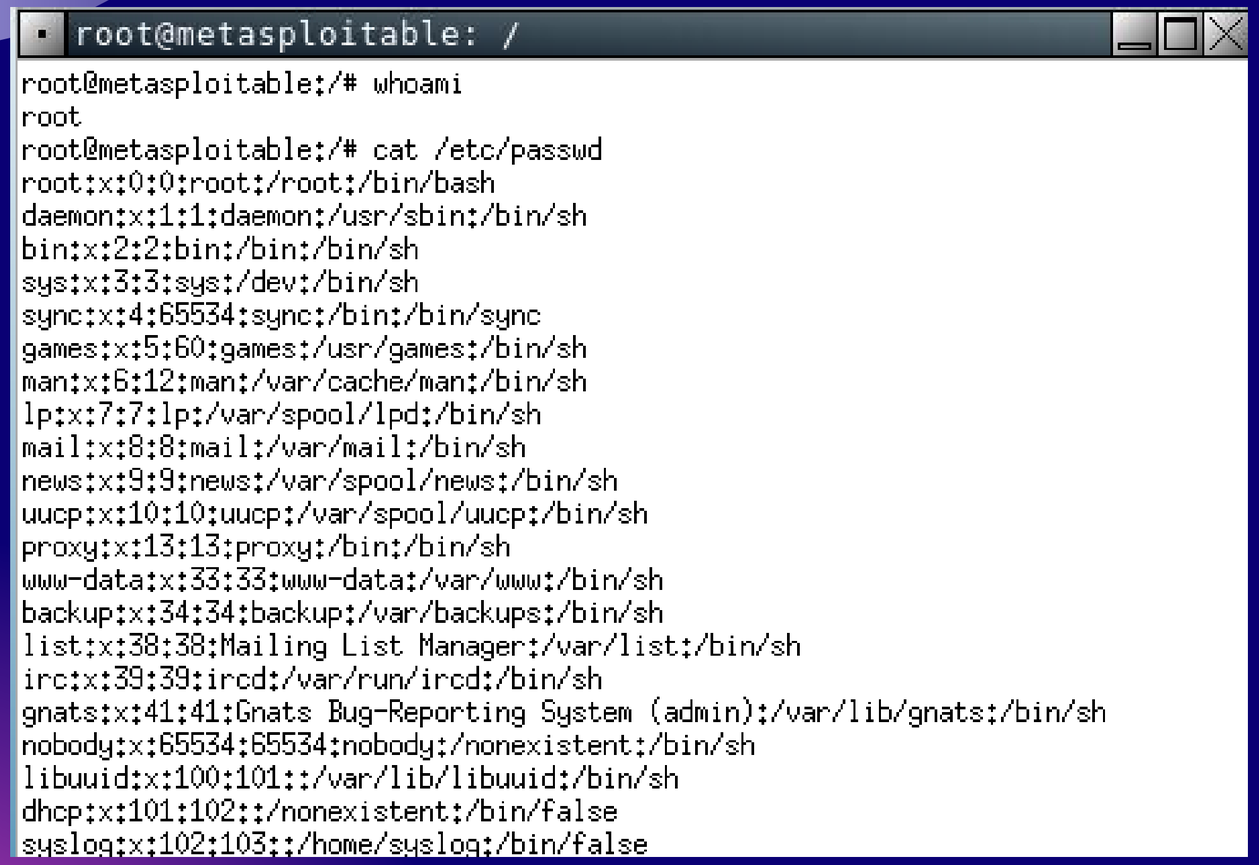



Shows the detailed vulnerability report from Nessus for the VNC Server weak password issue (Plugin #61708). The vulnerability has a CVSS score of 10.0 — the highest possible severity rating. Nessus confirmed it successfully exploited this vulnerability and gained remote shell access. The recommended solution is to secure the VNC service with a strong password immediately

# PART 5 EXPLOITATION

In this part, we explored the Metasploitable target system after successfully gaining access through the VNC vulnerability. Once inside the system, we executed several commands to gather information without causing any damage. The ifconfig command confirmed the target machine's IP address as 192.168.56.102. The whoami command returned 'root', confirming we have the highest level of administrative privileges on the system. The cat /etc/passwd command revealed all user accounts stored on the system, including system accounts such as daemon, bin, www-data, mail, and syslog. This demonstrates the severe impact of leaving default credentials unchanged — an attacker with root access can view, modify, or delete any file on the entire system."






demonstrates three key post-exploitation commands executed on the Metasploitable target machine. First, ifconfig confirmed the target's IP address as 192.168.56.102. Second, whoami returned 'root', proving we have the highest level of system privileges. Third, cat /etc/passwd began listing user accounts, starting with the root account entry root:x:0:0:root:/root:/bin/bash, confirming full administrative access to the system

# THANK YOU